La sécurité IP: IPSec

Emmanuel Conchon, Olivier Blazy
(emmanuel.conchon@unilim.fr, olivier.blazy@unilim.fr)

Université de Limoges

Bibliographie

- Stallings, Cryptography and Network Security: Principles and Practice
  - Les schémas sont directement tirés de ce livre
- Cours réalisé à partir des supports de A. Guermouche, B. Cousin et O. Blazy

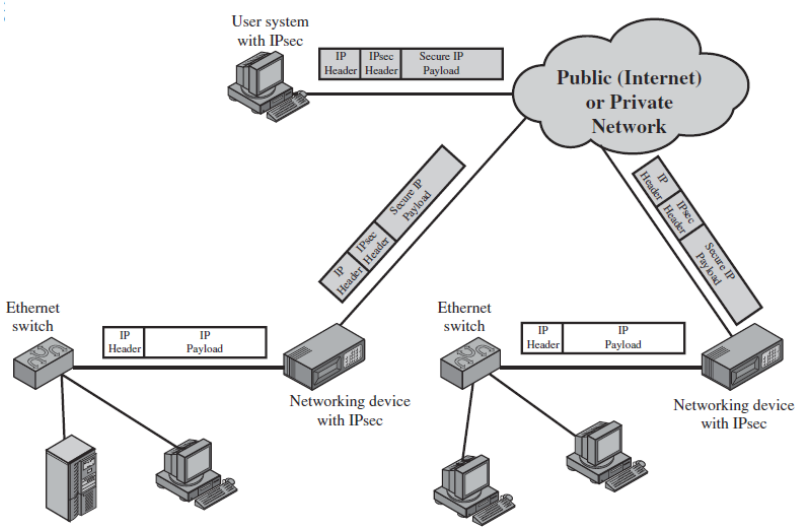
- RFC
  - 1636: Security in the Internet Architecture
  - 4301: Security Architecture for IP
  - 4302: IP Authentication Header
  - 4303: IP Encapsulating Security Payload (ESP)
  - 4306: Internet Key Exchange (IKEv2) Protocol
  - 6071: IP Security (IPsec) and Internet Key Exchange (IKE) Document Roadmap
  - 8221: Cryptographic Algorithm Implementation Requirements and Usage Guidance

Présentation générale

- Les problèmes de sécurité réseaux sont apparus très tôt sur Internet
  - En 1994 sort le premier RFC dédié à la sécurité, le RFC 1636
  - A l'époque on assiste à une multiplication des attaques de types spoofing et MIM

- Une des réponses pour la sécurité réseau a été IPSec
  - IPSec offre un cadre général pour permettre à deux stations de communiquer de manière sécurisée en assurant
    - Fonctionne avec IPv4 ou IPv6
    - Adaptable et paramétrable
  - Il permet d'assurer un transport sécurisé des données et d'assurer l'authentification des stations communicantes
  - Il permet également la mise en place de tunnels de communication pour des accès sécurisés distants
    - VPN IPSec

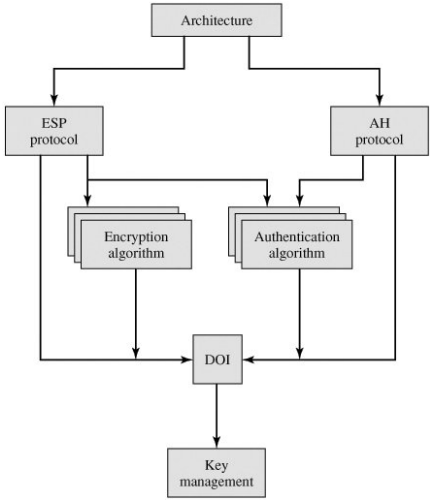
Scénario IPSec



IPSEC

- IPSec est situé au dessous de la couche transport
  - Transparent pour les applications et les utilisateurs une fois mis en place
- Il est définit dans un très grand nombre de RFC
  - Première définition RFC 2401, 2402, ….
  - Version actuelle: RFC 4301, 4302,…, 4309, 4478, 4543, 4555, 4621, 4718, 4806, 4809, 4835, 4945, 6071, 7321, 8221
    - Et certainement encore d'autres que j'ai oubliées ^^
- Il fournit
  - Un protocole d'authentification basé sur l'en-tête (AH: Authentication Header)
    - N'est plus utilisé dans la version actuelle mais persiste pour des questions de retro compatibilité
  - Un protocole de chiffrement (ESP: Encapsulating Security Payload)
    - Peut également assurer de l'authentification
  - Un mécanisme d'échange de clés (IKE)

L'architecture IPSec



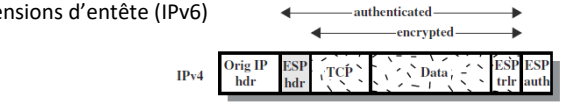
Les services IPSec

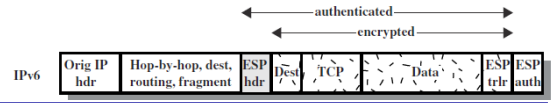
- IPSec propose une liste de services de sécurité au niveau de la couche IP
  - Contrôle d'accès
  - Contrôle d'intégrité
  - Authentification de l'origine des données
  - Rejet des paquets rejoués
  - Confidentialité des données
  - Confidentialité des flux
- Mise en œuvre

	AH	ESP (encryption only)	ESP (encryption plus authentication)
Access control	✔	✔	✔
Connectionless integrity	✔		✔
Data origin authentication	✔		✔
Rejection of replayed packets	✔	✔	✔
Confidentiality		✔	✔
Limited traffic flow confidentiality		✔	✔

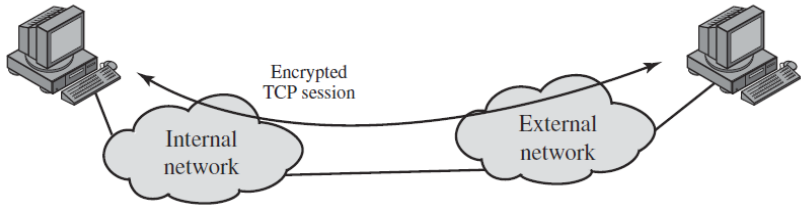
Les modes de fonctionnement d'IPSec

- Que ce soit avec AH ou avec ESP, deux modes d'utilisation sont offerts
  - Transport mode
  - Tunnel mode
- Le mode transport
  - Propose une sécurité aux couches supérieures à IP
  - Le chiffrement n'affecte que la payload du paquet IP et ne touche pas à l'entête (IPv4 & IPv6) ou aux extensions d'entête (IPv6)



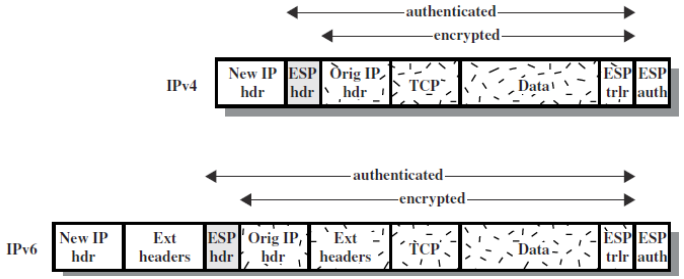


Les modes de fonctionnement d'IPSec

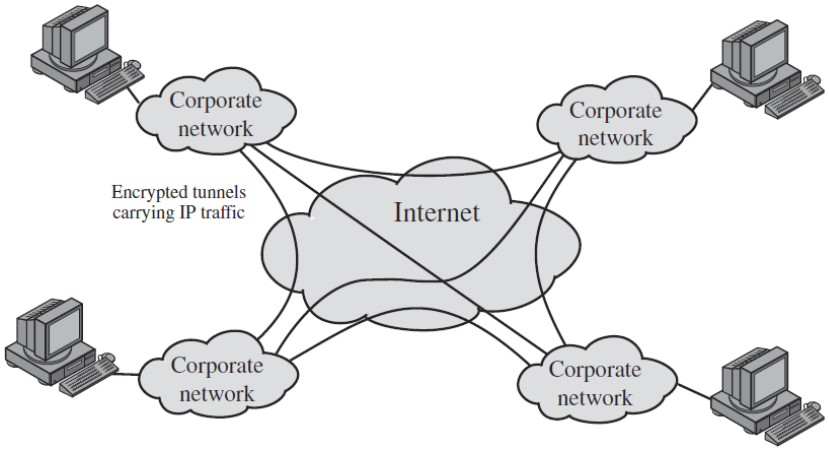


Les modes de fonctionnement d'IPSec

- Le mode tunnel
  - Propose une protection à tout le paquet IP en ajoutant de nouveaux champs au paquet IP et en générant un nouvel en-tête IP
    - Ce nouveau paquet, plus grand, peut avoir des sources et des destinations différente du paquet transporté



Les modes de fonctionnement d'IPSec



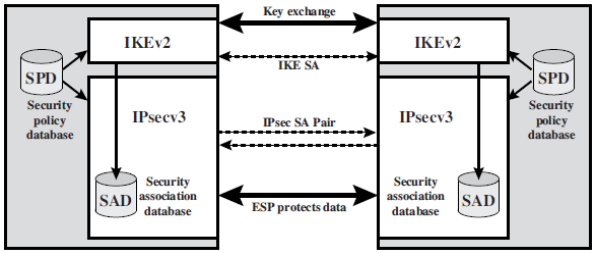
Les modes de fonctionnement d'IPSec

- Résumé des fonctionnalité des deux modes

	Transport Mode SA	Tunnel Mode SA
AH	Authenticates IP payload and selected portions of IP header and IPv6 extension headers.	Authenticates entire inner IP packet (inner header plus IP payload) plus selected portions of outer IP header and outer IPv6 extension headers.
ESP	Encrypts IP payload and any IPv6 extension headers following the ESP header.	Encrypts entire inner IP packet.
ESP with Authentication	Encrypts IP payload and any IPv6 extension headers following the ESP header. Authenticates IP payload but not IP header.	Encrypts entire inner IP packet. Authenticates inner IP packet.

Les associations de sécurité

- Architecture système



- Repose sur l'interaction de deux bases de données
  - Une base d'association de sécurité (SADB)
  - Une base de politiques de sécurité (SPD)

Les associations de sécurité

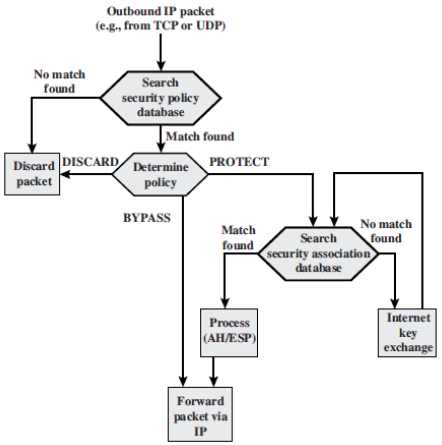
- La base SADB va stocker des associations de sécurité (SA)
  - Une SA est un lien logique unidirectionnel entre un émetteur et un récepteur qui propose des services de sécurité au trafic transporté
  - Pour un lien bidirectionnel, deux SA sont mises en place
  - Les SA sont offertes aux services de sécurité pour l'utilisation d'un mode AH ou ESP
  - Elles d'identifient à l'aide
    - D'un SPI (Security Parameter Index)
    - D'une adresse IP de destination
    - D'un identifiant du protocole de sécurité utilisé
- La base SADB va donc associer les SA aux paramètres de sécurité

Les associations de sécurité

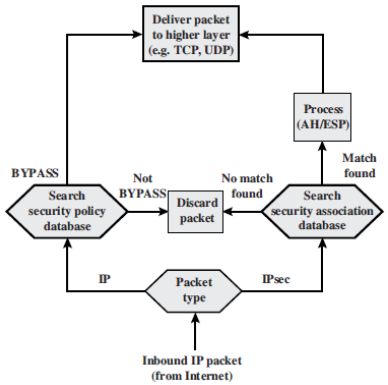
- La base SPD va stocker les relations entre le trafic IP et les SA
  - Une entrée va donc contenir un sous ensemble de trafics IP et pointer vers la SA qui va gérer ce sous ensemble
  - Une entrée se définit par un ensemble de valeurs de protocoles IP ou supérieurs appelé selector
  - Les selectors sont utilisés sur le trafic de sortie pour le mapper aux SA correspondantes
- Comme pour IP, IPSec fait du traitement paquet par paquet du trafic en entrée et en sortie d'une station

Traitement des paquets

- En sortie

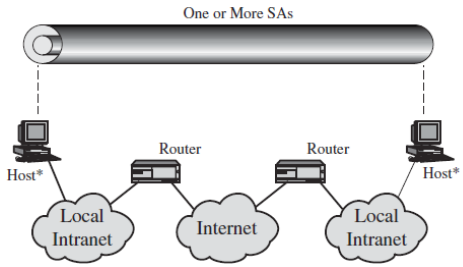


En entrée



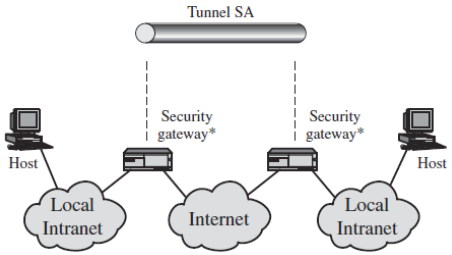
La combinaison de SA

- En fonction des réseaux à traverser, les SA a appliquer à un trafic IP pourront être différente
- La norme IPSec définit quatre cas de combinaison de SA
  - Dans le premier cas seuls les éléments d'extrémités sont compatibles IPSec
    - Etablissement d'une connexion de bout en bout

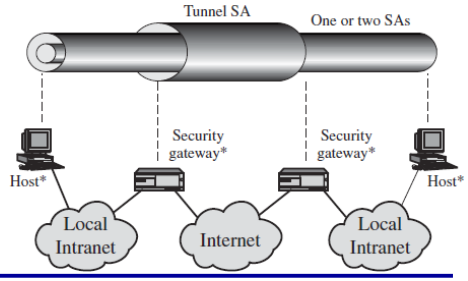


La combinaison de SA

- Dans le second cas, seul les élément d'interconnexion sont IPSec
  - Un seul tunnel est nécessaire pour assurer tous les services IPSec

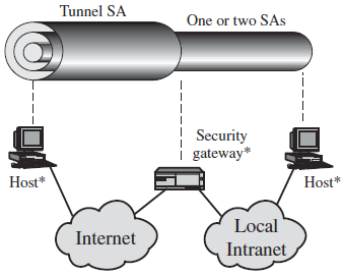


- Dans le troisième cas tous les éléments sont IPSec
  - Le mode tunnel n'est recommandé qu'entre les deux passerelles



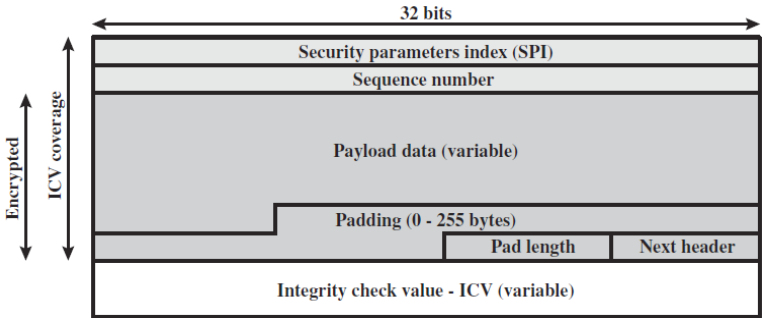
La combinaison de SA

- Le dernier cas représente la connexion distante vers un LAN sécurisé
  - Le tunnel intervient au niveau d'Internet uniquement



Le mode ESP

- Format des paquets IPSec en mode ESP pour l'authentification et la confidentialité



Le mode ESP

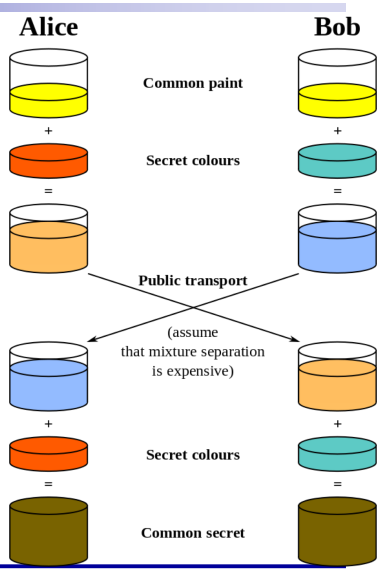
- Algorithmes disponibles
  - Chiffrement
    - DES
    - 3DES
    - CAST
    - BLOWFISH
    - TWOFISH,
    - RIJNDAEL
    - …
  - Authentification
    - HMAC-SHA1
    - HMAC-MD5
    - Keyed-MD5

IKE (Internet Key Management)

- L'objectif d'IKE dans IPSec est la distribution de clés secrètes
  - En général, il en faut 4 pour assurer à la fois l'intégrité et la confidentialité
    - 2 paires pour l'émission et la réception en mode AH ou ESP
- IPSec définit deux modes de gestion des clés
  - Manuel
    - L'administrateur configure lui-même avec ses clés et les clés du système distant à contacter
    - Ne passe pas à l'échelle s'il y a beaucoup de stations à relier
  - Automatique
    - Permet la création automatique de clé pour les SA
    - Le protocole par défaut pour réaliser cette opération est ISAKMP/Oakley
      - ★ *ISAKMP: protocole fournissant un cadre pour la gestion des clés*
      - ★ *Oakley: protocole basé sur Diffie-Hellman avec une sécurité renforcée utilisé dans la première version d'ISAKMP*

Rappels sur Diffie-Hellman

- Repose sur la fonction modulo
  - a et b représentent les clés secrètent d'Alice et Bob
    - Nombres choisis aléatoirement
  - g et p le message partagé par Alice et Bob pour générer le secret
    - Connus d'Oscar
  - Alice calcule $A=g^a \bmod p$ et le transmet à Bob
  - Bob calcule $B=g^b \bmod p$ et le transmet à Alice
  - Alice calcule ensuite $s = B^a \bmod p$
  - Bob calcule à son tour $s = A^b \bmod p$
  - Alice et Bob possèdent bien le même secret qu'ils peuvent ensuite utiliser comme clé secrète



Les limites de Diffie-Hellman

- Diffie-Hellman permet l'échange de clés mais
  - Il n'y a pas d'authentification des extrémités de la communication
    - Possibilité d'attaque MIM
  - Les calculs à effectuer lors de la réception du premier message sont couteux
    - Possibilité d'attaque par déni de service où l'attaquant va demander beaucoup de clés
      - ★ *Clogging attack*
- IKE Key Determination (ou Oakley)
  - Utilisation de cookies pour éviter les Clogging Attack
  - Les deux parties négocient un groupe
    - Permet de spécifier les paramètres globaux de Diffie-Hellman
  - Ajout de mécanismes d'authentification dans les échanges de DH
  - Utilisation de nonce pour éviter les attaques par rejeu
    - Les nonces sont générés localement et échangés ensuite de manière chiffrée

IKEv2

- 3 méthodes d'authentification peuvent être utilisées
  - Signatures numériques
    - ★ *Utilisation d'un hash chiffré des paramètres*
  - Chiffrement à clé publique
    - ★ *Chiffrement des paramètre avec sa clé privé*
  - Chiffrement symétrique

➢ Les échanges dans IKEv2 se déroulent par paires

- Dans le premier échange les pairs choisissent
  - les algorithmes cryptographiques à utiliser ainsi que les autres paramètres de sécurité
  - les nonces
  - les valeurs pour réaliser le protocole de Diffie-Hellman
- Dans le second échange les pairs
  - s'authentifient l'un vis-à-vis de l'autre
  - Mettent en place la première SA et la stocke dans la SADB

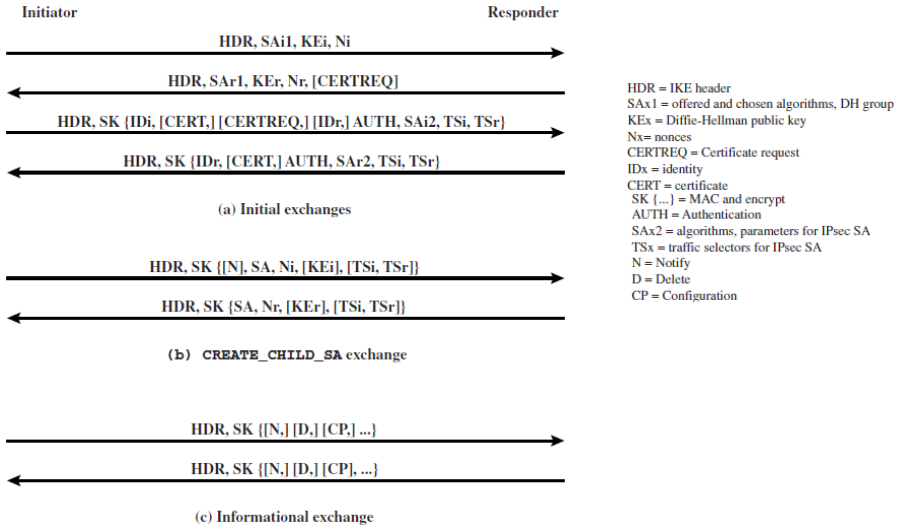


IKEv2

- Dans la pair d'échanges suivant des SA complémentaires peuvent être mises en place
- Enfin, l'échange d'information proprement dit commence

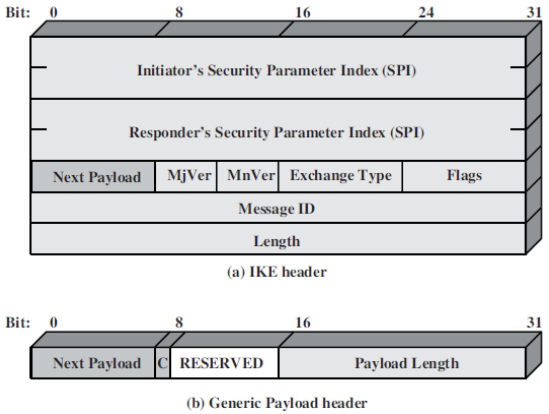


Echanges dans IKEv2





En-tête IKE





Les suites cryptographiques

- Dans IPSecv3 et IKEv2 de nombreux algorithmes cryptographiques sont disponibles aussi bien pour la confidentialité des données que pour l'authentification
  - Pour simplifier leur mise en œuvre les RFC 4308 et 6379 définissent des suites cryptographiques avec les paramètres recommandés
  - Exemple de la suite pour les VPN de la RFC 4308

	VPN-A	VPN-B
ESP encryption	3DES-CBC	AES-CBC (128-bit key)
ESP integrity	HMAC-SHA1-96	AES-XCBC-MAC-96
IKE encryption	3DES-CBC	AES-CBC (128-bit key)
IKE PRF	HMAC-SHA1	AES-XCBC-PRF-128
IKE Integrity	HMAC-SHA1-96	AES-XCBC-MAC-96
IKE DH group	1024-bit MODP	2048-bit MODP

- Un guide d'usage est également proposé dans la RFC 7321 pour la mise en œuvre de ces suites



Faiblesses d'IPSec

- Limitations dues à la gestion manuelle des clés
  - Seulement 4 milliards de numéros de séquences disponibles
  - AH et ESP utilisent ces numéros de séquence
  - Nécessité de créer une nouvelle SA au delà (et donc d'avoir une nouvelle clé)
- Problème de performances en Broadcast et en Multicast
- Traversé des équipements de sécurité
  - Comment faire du NAT avec IPSec ?
    - Pas de translation d'adresse possible pour un datagramme IPSec sinon l'intégrité des données n'est pas assurée
  - Comment gérer les règles de pare-feu?
    - Il n'a pas accès aux numéros de port, aux données chiffrées etc
    - Doit on déchiffrer le paquet avant d'appliquer les régles ?

